

Security Incident Report – Malware Injection via Brute Force Attack

Role: Cybersecurity Analyst

Company Website: yummyrecipesforme.com

Incident Type: Website Compromise (Brute Force + Malware Injection)

Tools Used: tcpdump, sandbox environment, source code inspection

Scenario:

You are a cybersecurity analyst for yummyrecipesforme.com, a website that sells recipes and cookbooks. A former employee has decided to lure users to a fake website with malware.

The former employee/ hacker executed a brute force attack to gain access to the web host. They repeatedly entered several known default passwords for the administrative account until they correctly guessed the right one. After they obtained the login credentials, they were able to access the admin panel and change the website's source code. They embedded a javascript function in the source code that prompted visitors to download and run a file upon visiting the website. After embedding the malware, the hacker changed the password to the administrative account. When customers download the file, they are redirected to a fake version of the website that contains the malware.

Several hours after the attack, multiple customers emailed yummyrecipesforme's helpdesk. They complained that the company's website had prompted them to download a file to access free recipes. The customers claimed that, after running the file, the address of the website changed and their personal computers began running more slowly.

In response to this incident, the website owner tries to log in to the admin panel but is unable to, so they reach out to the website hosting provider. You and other cybersecurity analysts are tasked with investigating this security event.

To address the incident, you create a sandbox environment to observe the suspicious website behavior. You run the network protocol analyzer tcpdump, then type in the URL for the website, yummyrecipesforme.com. As soon as the website loads, you are prompted to download an executable file to update your browser. You accept the download and allow the file to run. You then observe that your browser redirects you to a different URL, greatrecipesforme.com, which contains the malware.

A senior analyst confirms that the website was compromised. The analyst checks the source code for the website. They notice that javascript code had been added to prompt website visitors to download an executable file. Analysis of the downloaded file found a script that redirects the visitors' browsers from yummyrecipesforme.com to greatrecipesforme.com.

The cybersecurity team reports that the web server was impacted by a brute force attack. The disgruntled hacker was able to guess the password easily because the admin password was still set to the default password. Additionally, there were no controls in place to prevent a brute force attack.

Section 1:

The network protocol involved in this incident is the Hypertext Transfer Protocol (HTTP). In this case, it was used to:

- Establish the connection between users and the compromised website
- Trigger the JavaScript prompt to download a malicious executable file
- Redirect users' browsers to the fake website greatrecipesforme.com
- Deliver the malware payload via the downloaded file

No secure protocol (like HTTPS) was mentioned, which means traffic and credentials were likely transmitted in plaintext.

Section 2:

A disgruntled former employee executed a brute force attack on the administrative account of the website host. The attacker guessed the default password because there were no protections (like account lockout or multi-factor authentication) in place.

After gaining access, the attacker:

- Logged in to the admin panel
- Edited the website's source code
- Injected a JavaScript function that prompted users to download a file labeled as a browser update
- The malicious file was actually a redirect script that sent users to a fake website: greatrecipesforme.com

Users who downloaded and ran the file reported:

- Slow computer performance
- Unexpected redirects
- Suspicious behavior on their devices
- The real website admin could not access the admin panel because the attacker changed the login credentials.

The security team:

- Analyzed the event using a sandbox environment and tcpdump
- Identified the JavaScript malware and the redirection script
- Confirmed the brute force entry point and lack of password security

Section 3:

- To prevent brute force attacks in the future, I recommend implementing account lockout and rate-limiting policies. Here's how this helps:
- Account lockout temporarily disables login attempts after a set number of failed tries, slowing down brute force efforts.
- Rate limiting restricts the number of login attempts from a specific IP address within a certain time period.

Additional suggestions (optional for the future):

- Require strong, non-default passwords for all accounts
- Enforce multi-factor authentication (MFA) for admin-level logins

- Monitor failed login attempts with alerts for unusual patterns

Conclusion:

This incident shows the importance of securing administrative accounts and monitoring web application behavior. The attack was successful due to a weak password and lack of brute force protections.